

DPDP COMPLIANCE AUDIT

plane

Digital Personal Data Protection Act 2023



Grade B — Adequate

Indicative penalty exposure: up to Rs 925 crore

DPDP Act 2023 Section 33 (max) — not legal advice

Scanned: 22 March 2026

Files indexed: 3888

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

This codebase has 5 critical compliance gap(s) that require immediate attention under the Digital Personal Data Protection Act 2023. An additional 4 significant gap(s) were identified that should be addressed within 30 days. The estimated total remediation effort is 3.9–13.8 engineering days.

Total findings: 20

HIGH: 5

MEDIUM: 4

PASS: 11

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	22/22 (100%)	PASS
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	0/18 (0%)	FAIL
Section 8	10	10/10 (100%)	PASS
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	4.0/8 (50%)	WARN
Section 8(6)	8	5.6/8 (70%)	WARN
Section 9	6	6/6 (100%)	PASS
Section 11	6	6/6 (100%)	PASS
Section 16	4	0/4 (0%)	FAIL
Section 5	2	1.0/2 (50%)	WARN
Section 13 — Grievance Redressal	4	4/4 (100%)	PASS

Indicative Penalty Exposure

Up to ₹925 crore

Maximum indicative penalties under DPDP Act 2023 (Section 33 for violations identified in this scan.

Section 33(3): up to ₹575 crore

Section 33(4): up to ₹150 crore

Section 33(2): up to ₹150 crore

Section 33(1): up to ₹50 crore

Indicative maximum penalties under DPDP Act 2023 Schedule / Section 33. Actual penalties are at regulatory discretion and depend on breach severity, intent, duration, and cooperation. Not legal advice.

Estimated Total Remediation Effort: 3.9–13.8 engineering days

Rule	Section	Severity	File
CROSS_BORDER_TRANSFER_RISK	Section 16 — Cross-Border Transfer	HIGH	apps/api/plane/api/views/issue.py

PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT	Section 6 — Consent / Section 5 — Purpose Limitation	HIGH	apps/api/plane/bgtasks/event_tracking_task.py
CONSENT_MISSING	Section 6 — Consent	HIGH	MULTIPLE
HARDCODED_SECRET	Section 8(1) — Security	HIGH	apps/api/plane/api/views/issue.py
PLAINTEXT_PII_IN_LOGS	Section 8(1) — Security	HIGH	MULTIPLE
NO_ERROR_HANDLING_IN_AUTH	Section 8(6) — Breach	MEDIUM	apps/api/plane/authentication/utils/login.py
INCOMPLETE_DELETION_COVERAGE	Section 8 — Data Principal Rights	MEDIUM	N/A
AUDIT_TRAIL_PARTIAL	Section 8(4) — Audit Trail	MEDIUM	apps/api/plane/bgtasks/cleanup_task.py
THIRD_PARTY_PII_SHARING	Section 5 — Notice	MEDIUM	apps/admin/app/(all)/(dashboard)/general/form.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/api/plane/bgtasks/analytic_plot_export.py
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/api/plane/settings/common.py
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/api/plane/app/views/project/member.py
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/api/plane/app/views/workspace/invite.py
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/api/plane/middleware/logger.py
DELETION_MECHANISM_PRESENT	Section 8 — Data Principal Rights	PASS	apps/api/plane/bgtasks/cleanup_task.py
RETENTION_PRESENT	Section 8(3) — Retention	PASS	N/A
BREACH_INDICATORS_ADEQUATE	Section 8(6) — Breach	PASS	N/A
DATA_ACCESS_PRESENT	Section 11 — Right to Access	PASS	packages/services/src/workspace/workspace.service.ts
DATA_PORTABILITY_PRESENT	Section 11 — Data Portability	PASS	apps/api/plane/bgtasks/export_task.py
GRIEVANCE_OFFICER_PRESENT	Section 13 — Grievance Redressal	PASS	apps/space/components/account/terms-and-conditions.tsx

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (24.5–85 hours)

Fix immediately — these represent the highest legal exposure.

- Cross Border Transfer Risk — `views/issue.py` (4–12 hrs)
- Pii Flow To Analytics Without Consent — `bgtasks/event_tracking_task.py` (4–16 hrs)
- Consent Missing — MULTIPLE (10–39 hrs)
- Hardcoded Secret — `views/issue.py` (0.5–2 hrs)
- Plaintext Pii In Logs — MULTIPLE (6–16 hrs)

Week 2 — High Priority (7–25 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- No Error Handling In Auth — `utils/login.py` (1–3 hrs)
- Incomplete Deletion Coverage (2–8 hrs)
- Audit Trail Partial — `bgtasks/cleanup_task.py` (2–8 hrs)
- Third Party Pii Sharing — `general/form.tsx` (2–6 hrs)

Total estimated remediation effort: 31.5–110 hours (3.9–13.8 engineering days)

Details

Finding 1 of 20

[Section 16 — Cross-Border Transfer]

1. [HIGH] CROSS_BORDER_TRANSFER_RISK — `apps / api / plane / api / views / issue.py`

Estimated fix time: 4–12 hours

■ Penalty exposure: up to ■150 crore (DPDP Section 33(4))

Foreign cloud storage/CDN detected with PII models in repo. Cross-border transfer risk.

Finding 2 of 20

[Section 6 — Consent / Section 5 — Purpose Limitation]

2. [HIGH] PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT — apps / api / plane / bgtasks / event_tracking_task.py**Estimated fix time:** 4–16 hours**■ Penalty exposure:** up to **■50 crore** (DPDP Section 33(2))

PII flows from app/magic.py to analytics service (bgtasks/event_tracking_task.py) through 3 intermediate file(s). No analytics-specific consent detected on this flow path. DPDP Section 6 requires explicit consent for analytics processing separate from functional/auth consent.

Fix:

1. Add analytics consent checkbox at app/magic.py before user data is collected.
2. Store analytics consent separately from auth consent in your consent table with purpose='analytics'.
3. Check analytics consent in bgtasks/event_tracking_task.py before calling the analytics SDK.
4. If analytics is essential, disclose it in your privacy notice under Section 5 and obtain consent under Section 6.

Finding 3 of 20

[Section 6 — Consent]

3. [HIGH] CONSENT_MISSING — MULTIPLE:58**Evidence snippet:** EMAIL_HOST,**Estimated fix time:** 10–39 hours**■ Penalty exposure:** up to **■50 crore** (DPDP Section 33(2))**Affected files (14):**

- apps/api/plane/license/api/views/instance.py
- apps/api/plane/authentication/utils/login.py
- apps/admin/app/(all)/(home)/sign-in-form.tsx
- apps/api/plane/api/views/invite.py
- apps/api/plane/app/views/project/invite.py
- apps/web/app/routes/core.ts
- ... and 8 more files

Personal data collection and API endpoint detected with no consent mechanism. Detected in 14 files: instance.py, login.py, sign-in-form.tsx, invite.py and 10 more

Finding 4 of 20

[Section 8(1) — Security]

4. [HIGH] HARDCODED_SECRET — apps / api / plane / api / views / issue.py**Estimated fix time:** 0.5–2 hours**■ Penalty exposure:** up to **■250 crore** (DPDP Section 33(3))

Hardcoded aws_access_key detected. Secrets should be in environment variables.

Finding 5 of 20

[Section 8(1) — Security]

5. [HIGH] PLAINTEXT_PII_IN_LOGS — MULTIPLE**Estimated fix time:** 6–16 hours**■ Penalty exposure:** up to **■250 crore** (DPDP Section 33(3))**Affected files (16):**

- apps/api/plane/authentication/adapters/base.py
- apps/api/plane/authentication/adapters/oauth.py
- apps/api/plane/authentication/provider/oauth/github.py
- apps/api/plane/bgtasks/analytic_plot_export.py
- apps/api/plane/bgtasks/cleanup_task.py
- apps/api/plane/bgtasks/email_notification_task.py
- ... and 10 more files

PII keyword appears in logging call. Detected in 16 files: base.py, oauth.py, github.py, analytic_plot_export.py and 12 more

Finding 6 of 20

[Section 8(6) — Breach]

6. [MEDIUM] NO_ERROR_HANDLING_IN_AUTH — apps / api / plane / authentication / utils / login.py**Estimated fix time:** 1–3 hours**■ Penalty exposure:** up to **■50 crore** (DPDP Section 33(1))

Auth routes have no try/catch or try/except blocks. Errors may go unlogged.

Finding 7 of 20

[Section 8 — Data Principal Rights]

7. [MEDIUM] INCOMPLETE_DELETION_COVERAGE — N / A**Estimated fix time:** 2–8 hours**■ Penalty exposure:** up to **■50 crore** (DPDP Section 33(3))

Deletion mechanism detected but may not cover all PII storage. Uncovered files: apps/api/plane/db/__init__.py, apps/api/plane/db/management/__init__.py, apps/api/plane/db/models/__init__.py, apps/api/plane/db/models/analytic.py, apps/api/plane/db/models/api.py. DPDP Section 8 requires complete erasure of all personal data across all systems when a user requests deletion.

Fix:

1. Audit deletion endpoint to ensure it cascades to: apps/api/plane/db/__init__.py, apps/api/plane/db/management/__init__.py, apps/api/plane/db/models/__init__.py, apps/api/plane/db/models/analytic.py, apps/api/plane/db/models/api.py.
2. Use database CASCADE DELETE or explicit multi-table deletion.
3. Add a deletion checklist in code comments listing every table that stores user PII.

Finding 8 of 20

[Section 8(4) — Audit Trail]

8. [MEDIUM] AUDIT_TRAIL_PARTIAL — apps / api / plane / bgtasks / cleanup_task.py**Estimated fix time:** 2–8 hours**■ Penalty exposure:** up to **■25 crore** (DPDP Section 33(3))

Partial audit trail detected. Found: access logging, change tracking. Missing: dedicated audit model/table. DPDP Section 8(4) requires a structured audit trail with user identity, timestamp, action, and data accessed. A dedicated audit log table is required for proper compliance.

Finding 9 of 20

[Section 5 — Notice]

9. [MEDIUM] THIRD_PARTY_PII_SHARING — apps / admin / app / (all) / (dashboard) / general / form.tsx:87**Evidence snippet:** Email**Estimated fix time:** 2–6 hours■ **Penalty exposure:** up to ■50 crore (DPDP Section 33(2))

Personal data flows to a customer support platform. Ensure DPA with provider and disclose in privacy notice.

Fix:

1. Disclose this third-party data sharing in your privacy notice under Section 5.
2. Obtain explicit user consent for analytics/marketing use under Section 6 if applicable.
3. Ensure a Data Processing Agreement is in place with the provider.
4. Implement data minimization — only send fields necessary for the SDK's purpose.

Finding 10 of 20

[Section 6 — Consent]

10. [PASS] CONSENT_PRESENT — apps / api / plane / bgtasks / analytic_plot_export.py

Consent covered via imported module: apps/live/src/hocuspocus.ts

Finding 11 of 20

[Section 6 — Consent]

11. [PASS] CONSENT_PRESENT — apps / api / plane / settings / common.py

Framework auth/consent middleware detected in this file.

Finding 12 of 20

[Section 6 — Consent]

12. [PASS] CONSENT_PRESENT — apps / api / plane / app / views / project / member.py

Consent covered via imported module: apps/live/src/hocuspocus.ts

Finding 13 of 20

[Section 6 — Consent]

13. [PASS] CONSENT_PRESENT — apps / api / plane / app / views / workspace / invite.py

Consent covered via imported module: apps/live/src/hocuspocus.ts

Finding 14 of 20

[Section 6 — Consent]

14. [PASS] CONSENT_PRESENT — apps / api / plane / middleware / logger.py

Consent covered via imported module: apps/live/src/hocuspocus.ts

Finding 15 of 20

[Section 8 — Data Principal Rights]

15. [PASS] DELETION_MECHANISM_PRESENT — apps / api / plane / bgtasks / cleanup_task.py

Data deletion mechanism detected. Found 7 deletion endpoint(s) and 355 deletion signal(s). Cascade delete patterns detected.

Finding 16 of 20

[Section 8(3) — Retention]

16. [PASS] RETENTION_PRESENT — N / A

Retention signals detected across 13 model(s). Signals: deleted_at, created_at+cleanup, framework_retention_or_soft_delete, extractor_retention_signal, archived_at.

Finding 17 of 20

[Section 8(6) — Breach]

17. [PASS] BREACH_INDICATORS_ADEQUATE — N / A

Logging and/or breach alerting present.

Finding 18 of 20

[Section 11 — Right to Access]

18. [PASS] DATA_ACCESS_PRESENT — packages / services / src / workspace / workspace.service.ts

Data access endpoint detected for authenticated users.

Finding 19 of 20

[Section 11 — Data Portability]

19. [PASS] DATA_PORTABILITY_PRESENT — apps / api / plane / bgtasks / export_task.py

Data export/portability endpoint detected.

Finding 20 of 20

[Section 13 — Grievance Redressal]

20. [PASS] GRIEVANCE_OFFICER_PRESENT — apps / space / components / account / terms-and-conditions.tsx

Grievance Officer or Data Protection Officer contact information detected in codebase.